加雲聯網股份有限公司

SI/SM Project Security Management Plan

版 別：1.0

制訂日期：2024 年 5 月 XX 日

修訂日期：2024 年 5 月 XX 日

制修部門：XXX

頁 數：X

核准	審查	制定

Note: All involved personnel need to sign in review column after agree the work assigning.

文件發行/修訂記錄

版次	發行日期	生效日期	制修內容摘要
1.0			

Content

1.0 Object 目的 5
1.1 簡介 Introduction 5
1.2 本文件的目的和目標 Purposes and Objectives of This Document 5
2.0 Scope 適用範圍 6
2.1 本文件範圍 Scope of This Document 6
2.2 適用性和有效性 Applicability and Validity 6
2.2.1 適用性 Applicability 6
2.2.2 有效性 Validity 7
3.0 Responsibility 責任 7
4.0 Definitions 名詞定義 7
5.0 Instructions 作業說明 10
5.1 安全系統整合/維護服務專案概述 Secure SI/SM Project Overview 10
5.1.1 專案概述 Project Overview 10
5.1.2 系統或 IACS 自動化解決方案概述 System or IACS Automation Solution Overview.. 11
5.2 安全政策與管理理念 Security Policy and Management Philosophy 11
5.2.1 安全政策 Security Policy 11
5.2.2 安全管理理念 Security Management Philosophy 12
5.3 安全保證組織 Security Assurance Organization 14
5.3.1 專案安全保證組織 Project Security Assurance Organization 14
5.3.2 角色與責任 Roles and Responsibility 16
5.3.3 能力要求 Competency Requirements 20
5.3.4 其他相關計畫的介面管理 Management of Interfaces with Other Relevant Programs .. 21
5.4 安全績效目標與要求 Security Performance Targets and Requirements 22
5.4.1 風險分類矩陣 Risk Classification Matrix 22
5.4.2 安全目標 Security Targets 23
5.4.3 最低合理可行原則 ALARP Principle 24
5.4.4 安全要求 Security Requirements 24
5.5 安全計畫和任務 Security Program and Activities 25
5.5.1 安全整合/維護服務專案生命週期 Secure SI/SM Project Lifecycle 25
5.5.2 專案安全任務和/或活動 Project Security Tasks and/or Activities 25
5.5.3 專案安全保證產出文件和時間表 Project Security Assurance Deliverables and Schedule 33
5.5.4 服務水準協議/協定 Service Level Agreement (SLA) Protocol 37
5.6 安全保證方法 Secure Assurance Approach 37
5.6.1 一般原則 General Principles 37
5.6.2 安全基線要求和控制措施 Baseline Security Requirements and Control Measures 38
5.6.3 安全保證流程 Security Assurance Processes 38
5.6.4 安全研討 Security Studies 40
5.6.5 網宇威脅和漏洞日誌 Cyber Threats and Vulnerability Log 43
5.6.6 安全關鍵要素、要求和清單 Security Critical Elements, Requirements, and List 43

5.6.7 網宇威脅管理系統 Cyber Threats Management System 43
5.7 安全保證管理 Security Assurance Management 44
5.7.1 品質管理 Quality Management 44
5.7.2 安全管理 Security Management 44
5.7.3 安全審查、稽核和評鑑 Security Reviews, Audits, and Assessment 44
6.0 References： 45

1.0 Object 目的

1.1 簡介 Introduction

This document describes the required works scope and the implementation methods or processes of IACS Automation Solution for OT Security Requirements for dummy Energy Storage System's OT Security for an Integration/Maintenance Service Project (SI/SM Project) in accordance with the requirements specified for a Secure SI/SM Project during its Secure-by-design framework and lifecycle. It provides analytic, scientific, and systematic methods and management processes for implementing SI/SM Project security activities in order to ensure the compliance with the relevant SI/SM Project security requirements. It also provides guidance information for a Secure SI/SM Project during its Secure-by-design framework and lifecycle to establish its security management plan.

1.2 本文件的目的和目標 Purposes and Objectives of This Document

Systems' or IACS Automation Solutions' Security refers to the activities required to demonstrate that a System or IACS Automation Solution is fit for the purpose of providing its functionality, as defined in a Secure SI/SM Project security design criterion, in a secure manner. This document will provide the implementation requirements of Energy Storage System security and ensure its security in a systematic and logical manner. It provides the security requirements of a Secure SI/SM Project that will be considered and achieved throughout the duration of a Secure SI/SM Project lifecycle, and that any modification required as a result is included in the Concept/Specification (R0/R1), Development/Design and Development (R2), and Production/Implementation and Verification and Validation (R3) stages.

The purpose of this document will be:

1 To describe a Secure SI/SM Project security policy and responsibilities undertaken by the ICP's Project team in accordance with the Secure SI/SM Project security requirements;

2 To set out a Secure SI/SM Project security program for activities to be undertaken by the ICP'S Project team throughout the Secure SI/SM Project lifecycle to ensure the security of the System or IACS Automation Solution; and

3 To provide an analytic, scientific and management method or process for implementing the Secure SI/SM Project security activity in order to ensure compliance with the System or IACS Automation Solution security requirements.

The objectives of this document will be:

1 To describe the strategy, approach and method or process of a System or IACS Automation Solution security analysis to be performed;

2 To provide the security targets and to define the security targets acceptance criteria;

3 To describe the Secure SI/SM Project security assurance organization to management a System or IACS Automation Solution security activities during the Secure SI/SM Project lifecycle;

4 To specify the responsibilities for the management of a Secure SI/SM Project security activities; and

5 To describe how the security targets will be verified during the Secure SI/SM Project lifecycle.

2.0 Scope 適用範圍

2.1 本文件範圍 Scope of This Document

This document describes SI/SM Project security activities to be carried out by the ICP's Project team from a System level perspective. These activities should be programmed to fulfil the Secure SI/SM Project security requirements specified by

1 the System or IACS Automation Solution Users;
2 the Asset Owner;
3 the Customer or Client;
4 the applicable regulations, standards, code, and practices; or
5 the ICP's Project team, which derived from security risk assessments.

This document shall be applied to the ICP's Project team to develop their suitable security assurance activities, and to fulfil Systems' or IACS Automation Solutions' security requirements specified in the reference guidelines.

This document provides a guideline for a Secure SI/SM Project planning to cover the following subjects:

1 The objectives, purpose, scope and the used standards and/or practices of an SI/SM Project Security Management Plan;
2 How security organization and a Secure SI/SM Project security management being integrated into the Concept/Specification (R0/R1), Development/Design and Development (R2), and Production/Implementation and Verification and Validation (V&V) (R3) project life cycle stages;
3 The internal and external interfaces between SI/SM Project security activities, and the management of interfaces with other programs;
4 The approach, methods, processes to conduct SI/SM Project security activities throughout a Secure SI/SM Project lifecycle;
5 The detailed SI/SM Project security activities and/or tasks, and their associated milestones and deliverables;
6 The design and/or engineering change possibilities within a Secure SI/SM Project lifecycle and those should be via a Management of Change (MOC) procedure to carry out appropriative SI/SM Project security impact and/or risk assessments for them; and
7 The activities required for a Secure SI/SM Project security implementation and verification and validation processes.

2.2 適用性和有效性 Applicability and Validity

2.2.1 適用性 Applicability

The document is applicable to a Secure SI/SM Project whole lifecycle. If there are additional applicable regulations, standards, or code and practices, or any security requirement specified by the System or IACS Automation Solution Users (i.e., the

Product Users), the Asset Owner, or the Customer or Client, the ICP's Project team should moderately consider, apply them, and make necessary engineering justifications.

2.2.2 有效性 Validity

This document is valid throughout the entire SI/SM Project lifecycle as well as the Secure SI/SM Project after Implementation and Verification and Validation (R3) stage, such as Operation and Support/Maintenance (R4) and Decommissioning/Disposal (R5) (i.e, EOS/EOL) stages, if applicable, while performing the security management activities during the Secure SI/SM Project lifecycle. The ICP's Project team shall have a management system or program to support SI/SM Project security activities based on this document in relation to the Systems or IACS Automation Solutions. All documentation related to a System or IACS Automation Solution security shall comply with the ICP's company QMS, SI/SM Project quality assurance (QA) and/or security assurance processes to delivery for review.
This document should be reviewed and revised if necessary, such as

1 Applicable regulations, standards, or code and practices changes or revisions;
2 After a major security incident;
3 The ICP's company security policies changes or revisions;
4 Any ICP's company-designated periodic review; and
5 Other designated by task-based project review.

3.0 Responsibility 責任

The P/SSO will be responsible for the promotion of the security management framework of Secure SI/SM Projects and support the security operation of secure Systems' or IACS Automation Solutions' processes.

4.0 Definitions 名詞定義

Ac	Acceptable
AD	Advanced Mitigation Strategies
ALARP	AS Low As Reasonably Practicable
AN	Analyst
AP	Attack Potential
Ar	Acceptable with a technical review
BCR	Benefit-to-Cost Ratio
BPCS	Basic Process Control System
BU	Business Unit
CBA	Cost-Benefit Analysis
CPNI	Centre for the Protection of National Infrastructure
CRRF	Cyber Risk Reduction Factor

CSA	Cybersecurity Assessor
CSA SG	Cyber Security Agency of Singapore
CSRS/CRS	Cybersecurity Requirements Specification
CSMS/CMS	Cyber Security Management System
CUS	External Party (Product Users, the Asset Owner, etc.)
DES	Designer
DESH	Designer for HW
DESS	Designer for SW
DEV	Developer
DM	Defect Management
DP	Damage Potential
DRAR	Detailed Risk Assessment Requirements
ENISA	European Union Agency for Cybersecurity
EOL	End-of-Life
EOS	End-of-Service or End-of-Sale
ES	Equipment/Device Security
EUC	Equipment Under Control
EUCC	EU Cybersecurity Certification
FAT	Factory Acceptance Test
FR	Foundational Requirement
HLCRA	High-Level Cybersecurity Risk Assessment
HW	Hardware
IAC	Identification and Authentication Control
IACS	Industrial Automation and Control System
ICSA	Independent Cybersecurity Assessment / Assessor
ID	Identity or Identifier
IEC	International Electrotechnical Commission
IEEE	Institute of Electrical and Electronics Engineers
IMP	Implementor
INT	Integrator
ISO	International Organization for Standardization
IT	Information Technology
ML	Maturity Level
MOC	Management of Change
MoM	Minutes of Meeting

NIST	National Institute of Standards and Technology
NPV	Net Present Value
NS	Network Security
NTIA	National Telecommunications and Information Administration
O&M	Operation and Maintenance
OECD	Organization for Economic Co-operation and Development
OT	Operational Technology
PBS	Product Breakdown Structure
PCM	Project Configuration Manager
PDS	Product Security
PDSC	Product Security Committee
PJSC	Project Security Committee
PHA	Preliminary Hazard Analysis
PJS	Project Security
PJSC	Project Security Committee
PM	Project Manager
PQM	Project Quality Manager
PR	Programmer for Software
P/SSO	Project/System Security Office
QA	Quality Assurance
QMS	Quality Management System
RA	Resource Availability
RAGAGEP	Recognized and Generally Accepted Good Engineering Practices
RDF	Resource Description Framework
RQM	Requirements Manager
SA	System Administration
SAC	Security Analysis Center
SAT	Site Acceptance Test
SBOM	Software Bill of Materials
SCA	Static Code Analysis
SI	Integration Service
SIF	Safety Instrumented Function
SIS	Safety Instrumented System
SIT	Site Integration Test
SL	Security Level

SLA	Service Level Agreement
SL-A	Achieved Security Level
SL-C	Capabilities Security Level
SL-T	Target Security Level
SM	Maintenance Service / Security Management
STC	Security Test Center
SuC	System under Consideration
SUM	Security Update Management
SVV	Security Verification and Validation
SVVP	Security Verification and Validation Testing Plan
SW	Software
SYS	System Engineer
TAICS	Taiwan Association of Information and Communication Standards
TL	Technical Leader for SW
TR	Technical Report
TRA	Threat and Risk Assessment
TST	Tester
TTPs	Tactics, Techniques, and Procedures
TVRA	Threat, Vulnerability, and Risk Analysis
UC	Use Control
Ud	Undesirable
UK	United Kingdom
Un	Unacceptable
US	United States
V&V	Verification and Validation
VAL	Validator
VER	Verifier
ZCR	Zone and Conduit Requirements

5.0 Instructions 作業說明

5.1 安全系統整合/維護服務專案概述 Secure SI/SM Project Overview

5.1.1 專案概述 Project Overview

The generally overall context to which the Secure SI/SM Project should be presented in an SI/SM Project Security Management Plan. The corresponding project descriptions which including purposes, objectives, and scope, contracture requirements if applicable, delivery strategy, master planning, and relevant

stakeholders should be shown.

If this is a security issue that occurs in the Operation and Support/Maintenance (R4) and Decommissioning/Disposal (R5) stages of an SuC, the requirements specified in the ICP - The SI,SM Project and System Security Management Guideline and in the OT Security Requirements for this dummy project shall be followed.

5.1.2 系統或 IACS 自動化解決方案概述 System or IACS Automation Solution Overview

The following component security information and description of a System or IACS Automation Solution shall be prepared before its hand-over for operation or before its security patch/MOC for maintenance:

1. Component description;
2. Component identification;
3. Component label;
4. Version;
5. Identification during O&M, installation, configuration, deployment, and updates if applicable;
6. Proof of component integrity, primarily software;
7. Component category according to IEC 62443-4-2: software application, embedded component, host component, or network component;
8. Excluded parts of the component;
9. Component functionalities which are not considered due to deactivated by default and/or only activated for special cases and not the focal point;
10. Declaration of security requirements by stating a SL or by listing individual requirements, including possible requirement enhancements; and
11. Specification of the assumed attacker type (resistance level) by stating a SL or by describing the attacker (based on the definition given in the IEC 62443 series).

And the intended use of the SuC shall be prepared and listed as follows:

1. Intended use;
2. Use cases;
3. Threat model;
4. Operational environment (mandatory and optional);
5. Security functionality;
6. Implementation mechanisms for security properties; and
7. Information on whether PKI techniques are supported if appropriate.

5.2 安全政策與管理理念 Security Policy and Management Philosophy

5.2.1 安全政策 Security Policy

The System or IACS Automation Solution Security Policy Statement describes the ICP’s Project team commitment to the consideration of SuC security as a factor of

paramount importance in the Secure SI/SM Project lifecycle stages and its whole security lifecycle. During the Secure SI/SM Project stages, as a means of guiding the management of SuC security activities, the ICP's SI/SM Project team will adopt and adapt, where necessary, the System or IACS Automation Solution security-related regulatory, standards, and code of practices required by the Secure SI/SM Project. Consideration of security as well as that for the (functional) safety of the System or IACS Automation Solution, if applicable, in the design processes will be given the highest priority by the ICP's Project team.

It is the ICP's and its subcontractors/vendors/suppliers' duty if applicable to:

1 Comply with the security policy stated in the reference document of this document – the SI/SM Project and System Security Management Guideline;
2 Comply with the requirements specified in this document;
3 Comply with the specific System or IACS Automation Solution security requirements contained within the Secure SI/SM Project;
4 Participate in specific System or IACS Automation Solution security studies;
5 Highlight any threat identified during the course of their activities; and
6 Support the System or IACS Automation Solution security analysis and verify the performance of targets.

The Security Policy Statement of a Secure SI/SM Project and System or IACS Automation Solution should be stated in an SI/SM Project Security Management Plan. The project official management and Project Manager of the ICP's Project team should promise to give priority to and fully support the proposed security policy.

5.2.2 安全管理理念 Security Management Philosophy

The System and IACS Automation Solution security and safety (where applicable) management philosophy describes management's approach for ensuring the effectiveness of the SuC security and safety program and the achievement of SuC objectives.

The imperative philosophy is as follows:

1 Security and safety considerations will always take priority over other project considerations such as timescales, cost or operational factors within the context of the AS Low As Reasonably Practicable (ALARP) principle which will be customized to reflect local practices such as mitigation through rules and procedures if a design out is not practically feasible;
2 A unified approach to System or IACS Automation Solution security and safety management that cuts across the ICP's boundaries and, where appropriate, its subcontractors/vendors/suppliers;
3 All system security and safety activities will be planned based on an analysis of activities needed to meet the System and IACS Automation Solution security and safety requirements;
4 Pro-active approach to solving System and IACS Automation Solution security and safety issues in the definition of design control measures or operational and maintenance

controls;

5 Involvement of key engineering/design and Project staff in the System and IACS Automation Solution security and safety decision-making process and System and IACS Automation Solution security and safety review processes;

6 Close liaison amongst the security and safety organization and the engineering/design teams, implementation/integration staffs and test staffs to ensure the early identification of potential System and IACS Automation Solution security and safety problems or issues;

7 Active involvement of the engineering/design teams in the preparation of System and IACS Automation Solution security and safety studies including attendance at hazards/threats identification sessions and development of any design or operational control measures to reduce risks to a tolerable level;

8 Ownership and responsibility for resolution of hazards/threats rest with specific members within the nominated project team members;

9 Standardized System and IACS Automation Solution security and safety methods will be used across the project to facilitate the communication of System and IACS Automation Solution security and safety issues, the integration of analyses and the identification and resolution of interface-related issues;

10 Conflicts between security/safety-focused tasks, which aim at the avoidance of accidents and incidents, and other project progress tasks, where cost and capacity concerns are likely to be the prime driver, will be clearly identified and subject to trade-off studies, design or operational reviews to identify and implement optimized solutions within the context of the ALARP principle;

11 Conflicts between System and IACS Automation Solution security/safety and other project (and/or System and IACS Automation Solution) requirements will be clearly identified and subject to trade-off studies, design, or operational reviews to identify and implement optimized solutions; and

12 There will be regular and frequent monitoring of the System and IACS Automation Solution security and safety program progress and technical performance for the early detection of issues and deficiencies and prompt implementation of corrective action.

13 Request and training the team members and subcontractors/consultants to follow the requirement from the Employer:

- The Employer’s security requirements, policies, and procedures
- The Employer’s Management of Change (MOC) and Permit to Work (PtW) processes for changes involving devices, workstations, and servers and connections between them.
- The protection of the confidentiality of the Employer’s data. All the policies, procedures required to protect the confidentiality of the asset owner's data also shall be listed. The document and data should follow ISMS-P-03 Information Asset Management Procedure.

5.3 安全保證組織 Security Assurance Organization

5.3.1 專案安全保證組織 Project Security Assurance Organization

A typical organizational structure from System or IACS Automation Solution level perspectives and as a reference is shown in Figure1. when this System or IACS Automation Solution is also applicable functional safety requirements.

Notice that the System or IACS Automation Solution SI/SM Project engineering team, i.e. the SYS/DES/DEV/TL/AN/PR/IMP team, may be adjusted to plan and develop lower-level organizations in accordance with the ICP's existing procedures or practices; the project quality management team, of which including PCM and RQM, they may also make appropriate adjustment planning based on the ICP's existing project quality management practices; while the INT/TST and VER/VAL teams need to further follow the requirements stated in Section 6.7.2.2 of the guideline and those described in the SI/SM Project and System Security Management Guideline to establish related task groups and/or teams.

The following roles of a typical project security assurance organization must be planned by following the description stated in Section 6.3.2 of the guideline. Their related responsibilities and competency requirements should be arranged and specified in accordance with the reference provisions described in Section 6.3.3 of the guideline or referred to a specified source. The prescribed roles, responsibilities, and competency requirements stated in the SI/SM Project and System Security Management Guideline and cited by this document, such as TST, VER, VAL, and PJSC, should also be complied with.

PM – Project Manager

PQM – Project Quality Manager

PJSC – Project Security Committee – Led by PJS Leader and assigned by P/SSO

PJS – Project Security Leader that representative of PJSC and assigned by P/SSO

PCM – Project Configuration Manager (Can be assigned or delegated by PQM, if necessary)

RQM – Requirements Manager (Can be assigned or delegated by PQM, if necessary)

CUS – External Party (System or IACS Automation Solution Users (i.e., Product Users), the Asset Owner, etc.)

SYS – System Engineer

DES – Designer (Can be designated by SYS or concurrently, if necessary)

DEV – Developer, if necessary

DESH – Designer for HW, if necessary

DESS – Designer for SW, if necessary

TL – Technical Leader for SW, if necessary

AN – Analyst for SW, if necessary

PR – Programmer for SW, if necessary

IMP – Implementor, if applicable

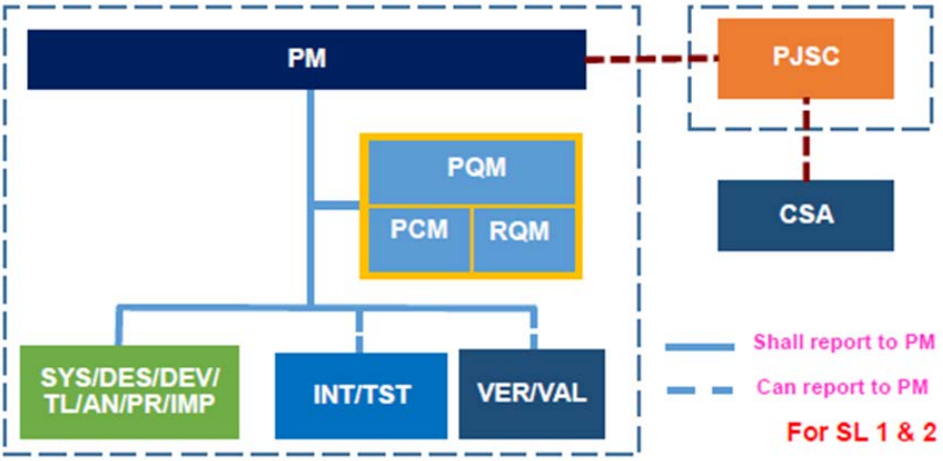
INT – Integrator, if applicable

TST – Tester

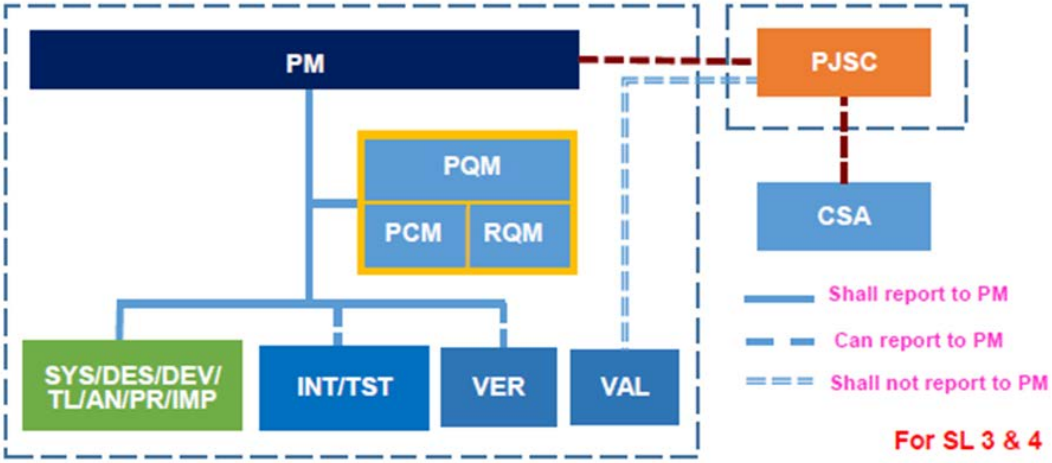
VER – Verifier – SAC and/or STC experts can be assigned by PJSC of P/SSO or PDSC of P/SSO to assist in execution

VAL – Validator – SAC and/or STC experts can be assigned by PJSC of P/SSO or PDSC of P/SSO to assist in execution

CSA – Cybersecurity Assessor – Can be assisted by PJSC of P/SSO, PDSC of P/SSO or appointed by qualified external experts if required



(a) For SL 1 & 2



(b) For SL 3 & 4

Figure1. Typical Project Security Assurance Organization.

As that illustrated in Figure1., the organizational independence requirements are basically planned as follows:

1 SYS/DES/DEV/TL/AN/PR/IMP should be separated to INT/TST and to Security Verification and Validation (SVV) (VER and VAL).
2 VER and VAL will be suggested to be independent for SL 3 & 4.
3 CSA should be planned if applicable and should be independent of the whole project team.
4 VER and VAL:

(1) Independent person for SL 1 & 2.
(2) Independent department for SL 3 & 4.

5 CSA:

(1) Independent department for SL 1 & 2.
(2) Independent organization for SL 3 & 4.

If the System or IACS Automation Solution does not require to comply with the functional safety requirements related to the IEC 61508 standards family and its specific applications' standards, the following required level of independence of TST/VER/VAL from SYS/DES/DEV/TL/AN/PR/IMP/INT shall comply as a minimum:

1 Penetration testing – Independent department or organization;
2 Security requirements testing – Independent department;
3 Threat mitigation testing – Independent department (if required and necessary);
4 Abuse case testing – Independent person (if required and necessary);
5 Attack surface analysis – Independent person (if required and necessary);
6 Known vulnerability scanning – Independent person (if required and necessary);
7 Static code analysis (SCA) – None (if required and necessary); and
8 SW composition analysis – None (if required and necessary).

In addition, based on different national or regulatory requirements, different Asset Owners' or Customer's/Clients' requirements, it may be necessary to implement Vulnerability Inspection and Testing of Systems or IACS Automation Solutions and to management Open Chain and SBOM security issues, the Secure SI/SM Project Manager should arrange and assign appropriate TST/VER/VAL team members to perform relevant activities or tasks, if applicable.

5.3.2 角色與責任 Roles and Responsibility

The roles and responsibility of security activities and tasks described in Section 5.5.2 and security assurance deliverables specified in Section 5.5.3 for a Secure SI/SM Project from system level perspectives shall be assigned and provided in a Secure IACS Automation Solutions SI/SM Project Security Management Plan. It shall comply with the independence level of a security assurance organization specified in

Section 5.3.1 to arrange human resources for each role and responsibility of a security assurance program. The proforma forms of Table 1 and Table 2 are suggested to use for human resources planning.

Table 1. Roles and Responsibility Assignment for Each Security Activity and/or Task on a Security Assurance Program of a Project.

Stage	Task ID	Task/Description	IMP	VER	VAL	Assessor
R0	SSA-PRO-001	Define Security Requirements for Tender	Implementor1	VER_assessor1	PM_person1	
R0	SSA-PRO-002	Evaluate Security Specification	Implementor1	VER_verifer1	PM_person1	VER_assessor1
R0	SSA-PRO-003	R0 Gate Review	Implementor1	VER_assessor1	PM_person1	
R1	SSA-PLN-001	Security planning & risk assessment	Implementor1	VER_assessor1、VER_verifer1	PM_person1	
R1	SSA-REQ-001	Systems security classification	Implementor2	VER_assessor1	PM_person1	
R1	SSA-REQ-002	Threat & Risk Assessment (Preliminary)	Implementor2	VER_assessor1	PM_person1	
R1	SSA-REQ-003	R1 Gate Review	Implementor2	VER_assessor1	PM_person1	
R2	SSA-DES-001	For each zone, design and document the technical and organizational cybersecurity policies, measures, or countermeasures	Implementor2	VER_assessor1	PM_person1	Assessor2
R2	SSA-DES-002	Review Security Architecture	Implementor2	VER_assessor1	PM_person1	
R2	SSA-DES-003	Review Security Controls	Implementor1	VER_assessor1	PM_person1	
R2	SSA-DES-004	R2 Gate Review	Implementor2、Implementor3	VER_assessor1	PM_person1	
R3	SSA-ENG-001	Implement SuC cybersecurity measures or countermeasures and conduct cybersecurity testing	Implementor1	VER_verifer1	PM_person1	
R3	SSA-ENG-002	Perform Source Code Review, if applicable	Implementor3	VER_verifer1	PM_person1	
R3	SSA-ENG-003	Perform Application Security Testing	Implementor3	VER_verifer2	PM_person1	
R3	SSA-	Perform System Security	Implementor3	VER_assessor1	PM_person1	

Stage	Task ID	Task/Description	IMP	VER	VAL	Assessor
	ENG-004	Testing				
R3	SSA-ENG-005	Perform Penetration Testing	Implementor2	VER_assessor1	PM_person1	
R3	SSA-ENG-006	R3 Gate Review	Implementor3	VER_assessor1、VER_verifer2	PM_person1	
R4	SSA-O&M-001	Perform security review	Implementor3	VER_verifer1	PM_person1	
R4	SSA-O&M-002	Perform type/setting/configuration management	Implementor1	VER_verifer1	PM_person1	
R4	SSA-O&M-003	Perform MOC	Implementor1	VER_verifer1	PM_person1	
R4	SSA-O&M-004	Regular security testing and/or evaluation	Implementor3	VER_verifer1	PM_person1	
R4	SSA-O&M-005	SuC's cybersecurity incident response and recovery	Implementor2	VER_assessor1	PM_person1	
R4	SSA-O&M-006	Perform continuous monitoring	Implementor2	VER_assessor1	PM_person1	
R4	SSA-O&M-007	R4 Gate Review	Implementor2、Implementor3	VER_assessor1	PM_person1	
R5	SSA-EOS-001	Preserve Information	Implementor1	VER_verifer1	PM_person1	
R5	SSA-EOS-002	Sanitize Media	Implementor1	VER_verifer1	PM_person1	
R5	SSA-EOS-003	Dispose Hardware and/or Software	Implementor1	VER_verifer1	PM_person1	
R5	SSA-EOS-004	R5 Gate Review	Implementor1	VER_assessor1	PM_person1	

Table 2. Roles and Responsibility Assignment for Security Assurance Deliverables.

Stage	Doc ID	Task/Description	IMP	VER	VAL	Assessor
R0	0.01	Tender Security Requirements	Implementor1	VER_assessor1	PM_person1	
R0	0.02	Security Compliance Report	Implementor1	VER_verifer1	PM_person1	VER_assessor1
R0	0.03	Security Requirements	Implementor1	VER_verifer1	PM_person1	VER_assessor1
R1	1.01	SI/SM Project Security Management Plan	Implementor1	VER_assessor1、VER_verifer1	PM_person1	
R1	1.02	Vendor (and/or Subcontractors) Security Management Plan	Implementor1	VER_assessor1、VER_verifer1	PM_person1	

Stage	Doc ID	Task/Description	IMP	VER	VAL	Assessor
R1	1.03	Security Policies and Procedures - Preliminary	Implementor1	VER_assessor1、VER_verifer1	PM_person1	
R1	1.04	Preliminary (or High-level) Security Requirements	Implementor2	VER_assessor1	PM_person1	
R1	1.05	Simple Network Diagram	Implementor2	VER_assessor1	PM_person1	
R1	1.06	Asset Inventory List - Preliminary	Implementor2	VER_assessor1	PM_person1	
R1	1.07	Threat and Risk Assessment Report - Preliminary	Implementor2	VER_assessor1	PM_person1	
R2	2.01	Asset Inventory List	Implementor2	VER_assessor1	PM_person1	Assessor2
R2	2.02	Network and Data Flow Diagram	Implementor2	VER_assessor1	PM_person1	Assessor2
R2	2.03	Detailed Threat and Risk Assessment Report	Implementor2	VER_assessor1	PM_person1	Assessor2
R2	2.04	Security Risk Mitigation Plan and Requirement Specifications	Implementor2	VER_assessor1	PM_person1	Assessor2
R3	3.01	IACS Automation Solutions/Asset Hardening Recommended Practices	Implementor1	VER_verifer1	PM_person1	
R3	3.02	Security Policies and Procedures (Security Functional Description Specification)	Implementor1	VER_verifer1	PM_person1	
R3	3.03	Security Solution Integration Plan for Security Policy and Procedure Design Best Practices	Implementor1	VER_verifer1	PM_person1	
R3	3.04	Security Inspection and Test Protocol	Implementor1	VER_verifer1	PM_person1	
R3	3.05	Security Verification and Validation Testing Plan (SVVP)	Implementor3	VER_verifer2	PM_person1	
R3	3.06	Incident response and recovery plan	Implementor3	VER_assessor1	PM_person1	
R3	3.07	FAT Test Cases – Related to security	Implementor3	VER_verifer2	PM_person1	
R3	3.08	FAT Report – Related to security	Implementor3	VER_verifer2	PM_person1	
R3	3.09	Source Codes Review Report	Implementor3	VER_verifer1	PM_person1	
R3	3.10	SBOM	Implementor3	VER_verifer1	PM_person1	
R3	3.11	Application and Vulnerability Assessment Testing Report	Implementor3	VER_verifer2	PM_person1	
R3	3.12	SAT Test Cases – Related to security	Implementor3	VER_verifer2	PM_person1	
R3	3.13	SAT Report – Related to security	Implementor3	VER_verifer2	PM_person1	
R3	3.15	SIT Report – Related to security	Implementor2	VER_assessor1	PM_person1	
R3	3.17	Penetration Testing Report – Related to security	Implementor2	VER_assessor1	PM_person1	
R3	3.18	SLA Protocol	Implementor3	VER_verifer2	PM_person1	

Stage	Doc ID	Task/Description	IMP	VER	VAL	Assessor
R3	3.19	Security Case – R3 stage	Implementor3	VER_assessor1、VER_verifer2	PM_person1	
R3	3.20	ICSA Report – R3 stage	Implementor3	VER_assessor1、VER_verifer2	PM_person1	

5.3.3 能力要求 Competency Requirements

The roles of the tasks planned for the Secure IACS Automation Solutions SI/SM Project should not only be subject to appropriate personnel competency requirements but should also be subject to organizational independence level requirements.

Security assurance key personnel in the organization, such as PM, PQM/PCM/RQM, PJSC/CSA, SYS, TL/AN (if applicable), TST, SVV, etc., their brief qualifications and/or curriculum vitae should be stated in an SI/SM Project Security Management Plan or displayed in the Competence Management System established by the ICP's human resources management organization. Their detailed information can be attached to the Annex of an SI/SM Project Security Management Plan or be referred to the ICP's human resources system as required.

For all the phases or stages of the secure IACS Automation Solutions SI/SM Project lifecycle, the key competences required for each role described in Section 5.3.2 in the execution of the Project should be compliant with the indications given by the ICP and with the essential training and knowledge about security to understand IEC 62443.

For the key security roles and responsibilities, such as PM, VER, VAL, TST, and CSA or Independent Security Assessor, their designed responsibilities and key competencies requirements are given in Table 3 of the guideline as a reference

5.3.3.1 安全背景調查 Security-Related Background Checks

During the execution of task [SSA-PLN-001] Security planning & risk assessment and development of output [1.02] Vendor (and/or Subcontractors) Security Management Plan, the security-related background checks for the team members and subcontractors/consultants should be performed, where feasible, and to the extent allowed by applicable law. It should provide the Background Checklist in the Vendor (and/or Subcontractors) Security Management Plan and make the records of Background Checklist for the team members and subcontractors/consultants.

5.3.3.2 知識與技能需求與評估 Knowledge and skills requirements and evaluation

Role	Personnel Name/ Suncontractor Name	Qualifications/ Experience required	Training that should be received	To be trained/ qualified
Implementor 1	XXX	More than 2 years	ISA IEC 62443	IEC 62443

		of experience in software development	Cybersecurity Fundamentals Specialist	aware training
Implementor 2	XXX	More than 2 years of experience in system integration	ISA IEC 62443 Cybersecurity Fundamentals Specialist	IEC 62443 aware training
Implementor 3	XXX	More than 2 years of experience in system development	ISA IEC 62443 Cybersecurity Design Specialist	IEC 62443 aware training
VER_assessor 1	XXX	More than 5 years of experience in software development	ISAIEC 62443 Cybersecurity Risk Assessment Specialist	IEC 62443 aware training
VER_assessor 2	XXX	More than 5 years of experience in system integration	ISA IEC 62443 Cybersecurity Design Specialist	Already met
VER_verifer1	XXX	More than 2 years of system testing	ISA IEC 62443 Cybersecurity Maintenance Specialist	Already met
VER_verifer2	XXX	More than 2 years of quality ensurence		Already met
PM_person1	XXX	More than 10 years of experience in project management	ISAIEC 62443 Cybersecurity Expert	Already met

Note: All involved personnel need to sign in review column in cover page after agree the work assigning.

5.3.4 其他相關計畫的介面管理 Management of Interfaces with Other Relevant Programs

The responsible personnel of interfaces between the Secure IACS Automation Solutions SI/SM Project management program and other stakeholders as well as management activities related to the following programs are assigned below:

1 PM_Name: Interfaces with Employer/Asset Owner for the project management, the tasks including

(1) To inform and get the approval of the PE/O of changes to new personnel (including ICP, subcontractor, and/or consultant personnel) who need to get access to the solution. It would be performed and reported in the regular meeting.

(2) To inform and get the approval of the PE/O of changes to personnel (including ICP, subcontractor, and/or consultant personnel) who no longer need access to the solution. It would be performed and reported in the regular

meeting.

2 PQM_Name: Interfaces with the (ICP's and Project's) Quality Management Program;
3 PJSC_Name: Interfaces with the (ICP's and Project's) Risk Management Program if applicable;
4 CSA_Name: Interfaces with the ICP's Information Security Management Program;
5 SYS_Name: Interfaces with the Project's Safety Management Program if applicable;
6 PCM_Name: Interfaces with the (ICP's or Project's) Supply Chain Management Programs;
7 DEV_Name: Interfaces with the Secure SI/SM Project Engineering Program if applicable; and
8 CUS_Name: Interfaces with the Secure SI/SM Project Maintenance Service Program.
9 PJS_Name: Project Security Leader that representative of PJSC to manage/audit/V &V the security of project

5.4 安全績效目標與要求 Security Performance Targets and Requirements

Unless the customer or client has specified applicable security goals, targets, objectives, and security requirements for the Secure IACS Automation Solution, or the Secure IACS Automation Solution is a low-risk application with adequacy and complete threat model and its security profile have been established, the security goals, targets, objectives, and security requirements shall be given in accordance with the requirements specified in the SI/SM Project Security Management Guideline.

5.4.1 風險分類矩陣 Risk Classification Matrix

A Risk Classification Matrix shall be assigned for a Secure IACS Automation Solutions SI/SM Project if needed. The tolerability of risk for a System or IACS Automation Solution will be in accordance with the classifications and criteria tabulated in Figure 2.

風險矩陣 (Risk Matrix)		衝擊 (Impact)			
		輕微的 (Minor) (1)	中度的 (Moderate) (2)	重大的 (Major) (3)	關鍵的 (Critical) (4)
概率/可能性(Likelihood)	必然的(Certain) (5)	5	10	15	20
	容易的(Likely) (4)	4	8	12	16
	可能的(Possible) (3)	3	6	9	12
	不太可能的(Unlikely) (2)	2	4	6	8
	罕見的(Remote) (1)	1	2	3	4

Figure 2. Risk Category for a System or IACS Automation Solution.

Where the definition of Risk Categories is given in Figure 3.

風險等級 (Risk Level)	數值 (Value)	風險類別 (Risk Category)	分級識別碼 (Ranking ID)	描述 (Description)
低 (Low)	<3	可接受的 (Acceptable)	Ac	通常不需要進一步降低風險 Further risk reduction not normally necessary
中 (Medium)	3-5	經技術審查可接受 (Acceptable with technical review)	Ar	優先級低於Ud網絡威脅，但仍有可能根據ALARP實現降低風險 Lower priority than Ud cyber threats, but risk reduction still to be achieved in accordance with ALARP
高 (High)	6-9	不受歡迎的 (Undesirable)	Ud	必須根據ALARP原則高度重視降低風險 High priority must be given to risk reduction in accordance with the ALARP principle
關鍵 (Critical)	>9	不可接受的 (Unacceptable)	Un	必須實現降低風險 Risk reduction must be achieved

Figure 3. Definition of Risk Categories.

Notice that the ALARP principle is described in Section 5.4.3 of this document. Detail information about the evaluation of the Impact and Likelihood categories of a security incident/accident can be further referred to Appendix A of this document.

5.4.2 安全目標 Security Targets

The Security Targets of a secure System or IACS Automation Solution shall be determined. It will be allocated and/or determined via a security risk assessment or specified by the ICP's, the Systems or IACS Automation Solutions Users, or the Asset Owner.

As demonstrated in Figure 2 and Figure 3, the Risk Category is divided into four categories: Acceptable (Ac), Acceptable with a technical review (Ar), Undesirable

(Ud), and Unacceptable (Un).

In a security risk assessment, one will calculate or evaluate the Unmitigated Risk ($R_{unmitigated}$) by using the expression $R_{unmitigated}$ = I*L. Where "I" is the impact and "L" is the likelihood of a threat. The risk category of a secure System or IACS Automation Solution depicted in Figure 2 and Figure 3 could be adopted for evaluating the $R_{unmitigated}$ if properly or necessary. In this example, the scoring value of an Acceptable (Ac) risk target is less than three (3), and the Tolerable risk target can be assigned as the scoring value equal to three (3).

In case the $R_{unmitigated}$ risk level is higher than Ac, the necessary risk reduction methods, countermeasures, compensating countermeasure, or treatments should be arranged in accordance with the principle described in Section 5.4.3.

Notice that, if applicable, in accordance with the requirements specified in IEC 62443-3-2, the security targets shall be allocated and established for each security Zone or Conduit partitions of the Systems or IACS Automation Solutions.

The Security Targets should be expressed as a SL with a vector format defined in Annex 3.3, IEC 62443-3-3: SL-? ([FR,] domain) = {IAC UC SI DC RDF TRE RA}, where

SL-? = (Required) is the SL type. The possible formats are:

- SL-T = Target SL;
- SL-A = Achieved SL; and
- SL-C = Capabilities SL.

[FR,] = (Optional) Field indicating the FR that the SL value applies. The FRs are written out in abbreviated form instead of numerical form to aid in readability.

domain = (Required) The applicable domain that the SL applies. Domains can refer to zones, control systems, subsystems, or components.

5.4.3 最低合理可行原則 ALARP Principle

The ALARP Principle specified in the ICP's SI-SM Project Security Management Planning Guideline will be applied to the Project and/or the System.

5.4.4 安全要求 Security Requirements

As that stated in Section 4.7, IEC 62443-3-2 regarding the requirements for ZCR 6.1 - Cyber Security Requirements Specification (CSRS or CRS), the CSRS (or CRS) shall be created and documented based on the outcome of the detailed security risk assessment as well as general security requirements based upon ICP or site-specific policies, standards, and relevant regulations.

At a minimum, the CSRS (or CRS) shall include the following:

1 SuC description – see IEC 62443-3-2 Section 4.7.3: ZCR 6.2;
1 Zone and conduit drawings – see IEC 62443-3-2 Section 4.7.4: ZCR 6.3;
2 Zone and conduit characteristics – see IEC 62443-3-2 Section 4.7.5: ZCR 6.4;
3 Operating environment assumptions – see IEC 62443-3-2 Section 4.7.6: ZCR 6.5;
4 Threat environment – see IEC 62443-3-2 Section 4.7.7: ZCR 6.6;

5 Organizational security policies – see IEC 62443-3-2 Section 4.7.8: ZCR 6.7;
6 Tolerable risk – see IEC 62443-3-2 Section 4.7.9: ZCR 6.8; and
7 Regulatory requirements – see IEC 62443-3-2 Section 4.7.10: ZCR 6.9.

The rationale and supplemental guidance on each of the requirements can be referred to the reference document – the SI/SM Project and System Security Management Guideline and Appendix A of this document. A typical workflow diagram outlining the primary steps required to establish zones and conduits and assess security risk is also provided for reference.

For a Secure SI/SM Project, the relevant functional requirements, SLs, and/or SL-T shall be specified. Detail information about secure design and security requirements specification can be referred to the reference document – the SI/SM Project and System Security Management Guideline.

5.5 安全計畫和任務 Security Program and Activities

5.5.1 安全整合/維護服務專案生命週期 Secure SI/SM Project Lifecycle

The Secure SI/SM Project lifecycle stages from the System-level perspective could be as follows:

Lifecycle Stage	Substage	Process
Concept/Specification (R0/R1)	Tendering/Acquisition (R0)	Tender Security Requirements
		Tender Security Evaluation
		C0 Control Gate
	Project Initiation (R1)	Security Planning & Risk Assessment
		C1 Control Gate
Development/Design and Development (R2)	N/A	Detailed risk assessment
		Critical Security Design Review
		C2 Control Gate
Production/Implementation and Verification and Validation (R3)	N/A	Implementation of system security countermeasures
		Application Security Testing
		System Security Acceptance Testing
		Penetration Testing
		C3 Control Gate
Operation and Support/Maintenance (R4) – if applicable	N/A	Audit & Continuous Monitoring
		C4 Control Gate, if applicable
Decommissioning/Disposal (R5) – if applicable	N/A	Secure Disposal
		C5 Control Gate, if applicable

5.5.2 專案安全任務和/或活動 Project Security Tasks and/or Activities

According to the requirements specified in IEC 62443-2-2 ED1 and Section 5.5.1 of this document, the corresponding activities and/or tasks and related work outputs of a Secure SI/SM Project lifecycle stages shall be properly developed by the Project Manager in accordance with the following baseline plan:

Stage/Sub-stage	Process	Activity/Task ID	Task/Activity Description	Deliverables
Concept/	Tender	SSA-PRO-	Define Security	Security Requirements

Stage/Sub-stage	Process	Activity/Task ID	Task/Activity Description	Deliverables
Specification - Tendering/Acquisition (R0)	Security Requirements	001	Requirements for Tender / Develop Security Requirements for Tender	for Tender
	Tender Security Evaluation	SSA-PRO-002	Evaluate Security Specification / Assessing of security control specifications proposed by the Vendors	1. Security compliance report 2. Security Requirements deviation
	C0 Control Gate	SSA-PRO-003	R0 Gate Review / Review security compliance report & check the Security Requirements deviation	Approve Security Requirements
Concept/ Specification - Project Initiation (R1)	Security Planning & Risk Assessment	SSA-PLN-001	Security planning & risk assessment / 1. Identification and confirmation of key security roles in the system development project 2. Develop project development lifecycle management & configuration management plan 3. Identify the use of secure design, architecture, and coding standards 4. Security management plans of subcontractors/suppliers and consultants 5. Plan the security policies and procedures	1. Security Management Plan: • Key security roles • Common security expectations • High-level Security Schedule 2. Project lifecycle Security Management Plan, including Configuration Management Plan 3. Security Subcontractors/Suppliers Management Plan – Vendor Security Management Plan 4. Security Policies and Procedures Management Plan
		SSA-REQ-001	Systems security classification / Identify the security classification of the System	1. Security classification of the System 2. High-level Security Requirements
		SSA-REQ-002	Threat & Risk Assessment (Preliminary) / 1. Review of Functional Requirements	1. TRA Report 2. Risk Register 3. Preliminary Asset Inventory List 4. Simple Network

Stage/Sub-stage	Process	Activity/Task ID	Task/Activity Description	Deliverables
			Specification 2. Threats and vulnerabilities identification 3. Initial establishment of SuC's Preliminary Asset Inventory List and Simple Network Diagram 4. Risk identification, analysis, and evaluation (i.e., Risk assessment) 5. Recommendations of appropriate security controls	Diagram
	C1 Control Gate	SSA-REQ-003	R1 Gate Review / Validate & Submit to Employer/Asset Owner: 1. The Project Security Management Plan, Configuration Management Plan, Security Policies and Procedures or Plan 2. TRA Report	1. Approve Security Management Plans, including security roles & responsibilities. 2. Approve Security Policies and Procedures/Plan 3. Approve TRA Report
Development/Design and Development (R2)	Detailed Risk Assessment, if applicable	SSA-DES-001	For each zone, design and document the technical and organizational cybersecurity policies, measures, or countermeasures / 1. Identify threats and document them 2. Identify and document vulnerabilities 3. Select a risk acceptance principle to establish cybersecurity requirements: • Apply Codes of Practice • Countermeasures for citing and reference systems	1. Asset Inventory List 2. Security Architecture: Network and Data Flow Diagram, if necessary 3. Security Controls: Security Risk Mitigation Plan and Requirement Specifications: • Functional Requirements • Security Countermeasures • Cybersecurity Policy and Procedure requirements 4. Security Detailed Risk Assessment Report and/or Updated TRA, if

Stage/Sub-stage	Process	Activity/Task ID	Task/Activity Description	Deliverables
			similarity • Conduct Detailed Risk Assessment 4. Confirm the SL-T of the zones or conduits 5. Output Cybersecurity Requirements Specifications	necessary
	Critical Security Design Review	SSA-DES-002	Review Security Architecture / Review trust boundaries, information entry and exit points and data flows	1. Approve Security Architecture: Network and Data Flow Diagram 2. Update Security Detailed Risk Assessment Report and/or TRA, if necessary
		SSA-DES-003	Review Security Controls / Review of security controls proposed in the System design, assessment of its effectiveness and recommendations	1. Approve Security Controls 2. Update Security Detailed Risk Assessment Report and/or TRA, if necessary
	C2 Control Gate	SSA-DES-004	R2 Gate Review / Validate & submit to the Employer/Asset Owner: 1. Asset Inventory List 2. Security Architecture 3. Security Controls 4. Risk Assessment Report and/or TRA	1. Approve Security Design 2. Update Security Detailed Risk Assessment Report and/or TRA, if necessary
Production/Implementation and Verification and Validation (R3)	Implementation of the System security countermeasures	SSA-ENG-001	Implement SuC cybersecurity measures or countermeasures and conduct cybersecurity testing / 1. Implementation of security countermeasures & cybersecurity Policy and Procedure requirements: • Assurance security	1. IACS Automation Solutions/Asset Hardening (Hardening) Recommended Practices 2. Security Policies and Procedures and/or Security Functional Description Specification: • Account

Stage/Sub-stage	Process	Activity/Task ID	Task/Activity Description	Deliverables
			• Network segmentation (architecture) security • Account management security • Configuration Management (CM) • IACS Automation Solutions/Asset Hardening • Wireless security, if applicable • Safety Instrumented System (SIS) security, if applicable • Remote access security, if applicable • Event management security, if applicable • Malware protection security, if applicable • Patch management security, if applicable • Backup/Restore security, if applicable 2. System development and maintenance 3. Development of Security Inspection and Test Protocol 4. Development of Security Solution Integration Plan for Security Policy and Procedure Design Best Practices 5. Development of incident response and recovery plan	Management • Vulnerability Management • Backup and Restore Procedure • Change and Patch Management Procedure • Logging, Monitoring, and Reporting Procedure • System Malware Protection Procedure 3. Security Inspection and Test Protocol 4. Security Solution Integration Plan for Security Policy and Procedure Design Best Practices 5. Incident response and recovery plan

Stage/Sub-stage	Process	Activity/Task ID	Task/Activity Description	Deliverables
	Application Security Testing	SSA-ENG-002	Perform Source Code Review, if applicable / Source code review of applications from Functional Requirements	1. Review Source Codes 2. Action arising from review
		SSA-ENG-003	Perform Application Security Testing / 1. Perform Security Solution Integration 2. Application Security Testing for Functional Requirements & Security Countermeasures	Approve Application Testing Results
	System Security Acceptance Testing	SSA-ENG-004	Perform System Security Testing / 1. Security Equipment Under Control (FAT) 2. Security Inspection and Test Protocol (Inspection and checking the Hardening, Security Policy and Procedure implementation results, Security Solution Integration results, etc.) 3. Security SAT 4. Security SIT Test, if necessary	1. Approve Hardening Report 2. Approve Security Policies and Procedures and/or Security Functional Description Specification 3. Approve Security Inspection and Test Protocol 4. Approve Security Solution Integration Plan for Security Policy and Procedure Design Best Practices 5. Approve Incident Response and Recovery Plan 6. Approve Testing Result: • Application and Vulnerability Assessment Testing Report, if applicable • Security FAT Report • Security SAT Report • Security SIT Report, if applicable

Stage/Sub-stage	Process	Activity/Task ID	Task/Activity Description	Deliverables
				7. Action arising from tests
	Penetration Testing	SSA-ENG-005	Perform Penetration Testing / Perform Penetration Testing based on threats on SuC environment: manually or with the assistance of automated software tools	1. Penetration Testing Report 2. Actions arising from tests
	C3 Control Gate	SSA-ENG-006	R3 Gate Review / Validate and check: 1. Security controls defined by the agreed upon requirements are implemented in the System correctly. 2. Mitigation actions arising from source code review reports, security test reports and/or penetration test reports are addressed	Update TRA, if necessary
Operation and Support/ Maintenance (R4) – if applicable	Audit & Continuous Monitoring, if applicable	SSA-O&M-001	Perform security review / Security review: 1. The security controls in place continue to be effective over time, in light of system and environmental changes. 2. Assessing technology assets and technical security controls, security policies addressing issue such as acceptable use 3. Network rights should be reviewed to determine if administrative security controls are effective	1. Security Review Results 2. Actions arising from review
		SSA-O&M-002	Perform type/setting/configuration management / 1. Review the type/setting/configura	1. Update Asset Inventory List, if necessary 2. Update security documentation, if

Stage/Sub-stage	Process	Activity/Task ID	Task/Activity Description	Deliverables
			tion management. 2. Assessment the changes to the system configuration of potential impact on the security of the System 3. Approve and changes in the operational environment	necessary
		SSA-O&M-003	Perform MOC / 1. Review the changes in the operational environment. 2. Approve and changes in the operational environment	1. Change Control decisions. 2. Update security documentation, Asset Inventory List, if necessary 3. Update TRA report, if necessary
		SSA-O&M-004	Regular security testing and/or evaluation / Scanning, conducting logs and continuously updating the security designs	Regular security testing and/or evaluation result
		SSA-O&M-005	SuC's cybersecurity incident response and recovery / Verify and exercise of shorten the impact time of security incidents	Cybersecurity incident response and recovery analysis and report, if applicable
		SSA-O&M-006	Perform continuous monitoring / Continuous Monitoring security reviews, self-assessments, vulnerability assessments and patch and end-point management	1. Security Reviews 2. Vulnerability Assessment results, if applicable 3. Actions arising from assessment, if applicable
	C4 Control Gate, if applicable	SSA-O&M-007	R4 Gate Review / 1. Validation of security reviews to ensure that built-in controls remain effective. 2. Validation of security assessment and reviews reports to ensure that Systems	Update TRA, if necessary

Stage/Sub-stage	Process	Activity/Task ID	Task/Activity Description	Deliverables
			and environmental changes are addressed. 3. Regular review of TRA reports and risk register to ensure that risks remain valid and are continually addressed	
Decommissioning/ Disposal (R5 – if applicable	Secure Decommissioning/Disposal, if applicable	SSA-EOS-001	Preserve Information / Select the archival method that would facilitate information retrieval in the future	1. Disposal Plan 2. Index & Location of Information
		SSA-EOS-002	Sanitize Media / Using approved equipment, techniques, and procedures according to relevant policies and regulations to sanitize the System's digital media	Media Sanitization Records
		SSA-EOS-003	Dispose Hardware and/or Software / 1. The disposal of software should comply with license agreements. 2. The disposal of hardware.	1. Decommissioned or disposal records. 2. Update Asset Inventory list, if necessary
	C5 Control Gate, if applicable	SSA-EOS-004	R5 Gate Review / 1. Validation preserved information. 2. Validation of sanitization records 3. Validation of Asset Inventory list	

5.5.3 專案安全保證產出文件和時間表 Project Security Assurance Deliverables and Schedule

The following planned list of a System or IACS Automation Solution security assurance documents to be produced during a Secure SI/SM Project lifecycle in its Concept/Specification (R0/R1), Development/Design and Development (R2), and Production/Implementation and Verification and Validation (R3) stages.

Item	Description	Concept/Specification			Development/Design and Development		Production/Implementation and Verification and Validation				Note
		Tendering/Acquisition		Project Initiation							
		Tender Security Requirements	Tender Security Evaluation	Security Planning & Risk Assessment	Detailed Risk Assessment	Critical Security Design Review	Implementation of the System security countermeasures	Application Security Testing	System Security Acceptance Testing	Penetration Testing	
		R0 (C0)		R1 (C1)	R2 (C2)		R3 (C3)				
0.01	Tender Security Requirements	P									If required
0.02	Security Compliance Report		P								If necessary
0.03	Security Requirements Deviation Analysis Reports (or Records)		P								If necessary
0.04	**C0 Control Gate – Formal Review Records**		P								
1.01	**SI/SM Project Security Management Plan**			P							Should cover the overall security lifecycle of the Project
1.02	Vendor (and/or Subcontractors) Security Management Plan			P							If applicable
1.03	Security Policies and Procedures - Preliminary			P							If required. Allows adoption of policies and procedures provided by the Asset Owner (Users) or Client
1.04	**Preliminary (or High-level) Security Requirements**			P							
1.05	**Simple Network Diagram**			P							Should include preliminary zones and conduits partition, as well as physical and logical network connection interface descriptions
1.06	**Asset Inventory List - Preliminary**			P							
1.07	Threat and Risk Assessment Report - Preliminary			P							Or HLCRA Report If necessary
1.08	**Security Risk Register - Preliminary**			P							Or Cyber Threats and Vulnerability Log - Preliminary
1.09	Security Case – R1 stage			P							If required
1.10	ICSA Report – R1 stage			P							If required
1.11	**C1 Control Gate – Formal Review Records**			P							

Item	Description	Concept/Specification			Development/Design and Development		Production/Implementation and Verification and Validation				Note
		Tendering/Acquisition		Project Initiation							
		Tender Security Requirements	Tender Security Evaluation	Security Planning & Risk Assessment	Detailed Risk Assessment	Critical Security Design Review	Implementation of the System security countermeasures	Application Security Testing	System Security Acceptance Testing	Penetration Testing	
		R0 (C0)		R1 (C1)	R2 (C2)		R3 (C3)				
2.01	**Asset Inventory List**				P	U*	U*	U*	U*		
2.02	**Network and Data Flow Diagram**				P	U*	U*	U*	U*		
2.03	Detailed Threat and Risk Assessment Report				P	U*	U*	U*	U*	U*	Or Detailed Cyber Risk Assessment Report, if necessary Detailed Security Risk Assessment Report and/or Updated TRA, if necessary
2.04	**Security Risk Mitigation Plan and Requirement Specifications**				P	U*	U*	U*	U*	U*	Or CSRS/CRS and Security Risk Mitigation Plan
2.05	Security Case – R2 stage					P					If required
2.06	ICSA Report – R2 stage					P					If required
2.07	**C2 Control Gate – Formal Review Records**					P					
3.01	IACS Automation Solutions/Asset Hardening Recommended Practices						P	U	U*		If required
3.02	**Security Policies and Procedures**						P	U	U*		Or Security Functional Description Specification, including: • Account Management • Vulnerability Management • Backup and Restore Procedure • Change and Patch Management Procedure • Logging, Monitoring, and Reporting Procedure • System Malware Protection Procedure
3.03	Security Solution						P	U	U*		If required or

Item	Description	Concept/Specification			Development/Design and Development		Production/Implementation and Verification and Validation				Note
		Tendering/Acquisition		Project Initiation							
		Tender Security Requirements	Tender Security Evaluation	Security Planning & Risk Assessment	Detailed Risk Assessment	Critical Security Design Review	Implementation of the System security countermeasures	Application Security Testing	System Security Acceptance Testing	Penetration Testing	
		R0 (C0)		R1 (C1)	R2 (C2)		R3 (C3)				
	Integration Plan for Security Policy and Procedure Design Best Practices										necessary
3.04	**Security Inspection and Test Protocol**						P	U*	U*		Including FAT, SAT, and/or SIT, if applicable
3.05	Security Verification and Validation Testing Plan (SVVP)						P	U*	U*		If required or necessary
3.06	Incident response and recovery plan						P	U	U*		If applicable
3.07	FAT Test Cases – Related to security							P			If required or necessary
3.08	**FAT Report – Related to security**							P			
3.09	Source Codes Review Report							P	U*	U*	If applicable
3.10	SBOM							P	U*	U*	If required or necessary
3.11	Application and Vulnerability Assessment Testing Report								P		If applicable
3.12	SAT Test Cases – Related to security								P		If required or necessary
3.13	**SAT Report – Related to security**								P		
3.14	SIT Test Cases – Related to security								P		If required or necessary
3.15	SIT Report – Related to security								P		If required or necessary
3.16	Penetration Testing Cases – Related to security									P	If required
3.17	Penetration Testing Report – Related to security									P	If required
3.18	SLA Protocol									P	If required. For supporting the security management during the stages in R4 and in R5
3.19	Security Case – R3 stage									P	If required
3.20	ICSA Report – R3 stage									P	If required
3.21	**C3 Control Gate – Formal Review Records**									P	
Note		P: Prepare; U: Update; U*: Update, if necessary									

5.5.4 服務水準協議/協定 Service Level Agreement (SLA) Protocol

The Client/Asset Owner or User of the System or IACS Automation Solution may sign a maintenance service contract with the SI/SM Service Provider regarding the Operation and Support/Maintenance (R4) and/or Decommissioning/Disposal (R5) stages. At this time, the Project Manager should complete the relevant SLA Protocol before the end of Production/Implementation and Verification and Validation (R3) stage, in addition to complying with the requirements of Section 5.5.2 of this document regarding the processes, tasks/activities, and document delivery of the R4 and/or R5 stages, its content should also comply with the requirements of the SI/SM Project and System Security Management Guideline.

5.6 安全保證方法 Secure Assurance Approach

5.6.1 一般原則 General Principles

Cybersecurity assurance programs can utilize the good practice developed in IEC 62443-3-3, IEC 62443-2-4, IEC 62443-2-1 ED1, and/or IEC 62443-2-1 ED2 for Systems and IACS Automation Solutions. These standards focus upon the management for integration and/or O&M of a secure System or IACS Automation Solution during its whole lifecycle.

The fundamental secure design principles include:

1 Secure by Design: A design principle where security measures are implemented early in the lifecycle of an IACS;

2 Reduce Attack Surface: A design principle where the physical and functional interfaces of an IACS that can be accessed and exposed to potential attack are minimized, making it more difficult for an attack to succeed:

(1) Access control (IAC and UC);
(2) Network segmentation;
(3) Least function; and
(4) Least privilege.

3 Defense-in-Depth: Being defined as the provision of multiple security protections, especially in layers, with the intent to delay or prevent an attack;

4 Essential Functions: To maintain health, safety, the environment, and availability of an Equipment Under Control (EUC). Essential functions include:

(1) The Safety-related Control Functions, or Safety Instrumented Function (SIF);
(2) The critical control function; and
(3) The ability of the operator to view and manipulate an EUC.

The fundamental defense-in-depth philosophy of a System or IACS Automation Solution used in this document is based on the guidance specified the SI/SM Project and System Security Management Guideline.

In addition to referring to the above security principles, the Secure SI/SM Project

team can explore suitable security principles based on best-practices of the specific application sector of a System or IACS Automation Solution. For example, CLC TS 50701 for railway applications, ISO/SAE 21434 and SAE J 3061 for road vehicles, and in general sectors, the United Kingdom (UK) Centre for the Protection of National Infrastructure (CPNI) good practice guide for process control and SCADA security, etc.

The security principles for a Secure System or IACS Automation Solution, if possible, should be stated in the Security Policies and Procedures, and the SLA Protocol, if required.

5.6.2 安全基線要求和控制措施 Baseline Security Requirements and Control Measures

The list of threats, vulnerabilities, and threat events related to a Secure System or IACS Automation Solution should be collected as far as possible in accordance with the requirements specified in the SI/SM Project and System Security Management Guideline, and their security requirements, security countermeasures, security profiles, baseline security requirements and control measures should be established and continuously updated during its Operation and Support/Maintenance (R4) and/or Decommissioning/Disposal (5) stages, if applicable and if required.

The ICP's P/SSO shall be responsible for maintaining the novelty, completeness, and correctness of the aforementioned threat models. The Secure SI/SM Project team shall work closely with the PJSC led by a PJS Leader (or PDSC led by a PDS Leader) who responsible for and related to the System and Automation Solution security assurance to obtain the necessary security information and technology support.

Baseline Security Requirements and Control Measures are important input information for the specified security requirements and preliminary security risk assessment of a System or IACS Automation Solution in the early stages of its SI/SM Project execution.

5.6.3 安全保證流程 Security Assurance Processes

A typical Secure System or IACS Automation Solution SI/SM Project Security Assurance Processes should include:

1 Define the scope of the Security Assurance Program;
2 Plan the tasks and activities of the Security Assurance Program;
3 Establish a plan for Security Assurance Management;
4 Perform necessary cyber threats identification, vulnerability analysis, cybersecurity risk assessment;
5 Determine the CSRS or CRS;
6 Perform Secure by Design on the System or IACS Automation Solution for its SI/SM Project execution (including Concept/Specification (R0/R1), Development/Design and Development (R2), Production/Implementation and Verification and Validation (R3) stages) tasks and activities in accordance with this document and the reference document – the SI/SM Project and System Security Management Guideline.

7 Plan the tasks and activities of the SVV in accordance with this document, which including:

(1) FAT Test Package:
- Weakness Detection and Vulnerability Testing: Weakness, Vulnerability Scanning identifies systems and system attributes, and attempts to detect known weaknesses and vulnerabilities;
- Threat Mitigation Testing: Verify the measures or countermeasures implemented to mitigate the threat and test the resilience of these implemented measures or countermeasures.

(2) SAT Test Package and Penetration testing:
- Repeat the FAT Test Package on SAT, if required;
- Penetration Testing: Penetration testing is a cybersecurity test used to determine how intrusion testers simulate real-world attacks to circumvent a system or cybersecurity function. Penetration testing is designed to demonstrate the resilience of IACS' SuC to identified threats and risks. It must be based on the detailed risk assessment results and the specific Tactics, Techniques, and Procedures (TTPs) attack possibilities and attack paths.

(3) SIT Test Package, if required or necessary:
- Penetration Testing;
- In some cases, it may be testing led by the Asset Owner or User.

8 Verify that the CSRS (or CRS) and SL-T of each Zone and each Conduit of a Secure System or IACS Automation Solution is valid and achieved. In some cases, it can be carried out with reference to the requirements of IEC 62443-2-2 ED1;

9 Validate the Secure System’s or IACS Automation Solution's cyber threats and security/cybersecurity risks have been effectively controlled to ALARP or Ac risk levels as expected;

10 Register and manage the Cyber Threats and Vulnerability Log (i.e., the Security Risk Register) for a Secure System or IACS Automation Solution and verify that all CSRS (or CRS) or security measures or countermeasures have been implemented correctly and effectively, and demonstration evidence is obtained, closing all cybersecurity requirements and cyber threats;

11 Establish an SLA Protocol, if required, for supporting the security management during the stages in Operation and Support/Maintenance (R4) and/or in Decommissioning/Disposal (R5).

12 Perform management tasks and activities of the Security Management Program and management plan, including various types of reviews, checking, inspection, audits, verification and validation, assessment, and change management related to security.

A lifecycle management simplified V-model for a System level perspective is provided in Section 5.5. The planned project configuration control stages for a Secure

SI/SM Project lifecycle and its relevant tasks and/or activities are provided in Section 5.5.2 and Section 5.5.3.

The necessary security assurance processes, activities or tasks should be appropriately carried out based on this baseline plan.

5.6.4 安全研討 Security Studies

A Security Studies can be divided into:

1 Concept/Specification - Project Initiation (R1)

(1) Discuss and develop security policies;
(2) Identify existing security requirements for the acquisition process;
(3) Define project security scope (including security objectives, constraints, and stakeholders);
(4) Establish the Project security management plan;
(5) Identify SuC;
(6) Preliminary partition of Zones and Conduits of SuC;
(7) Perform preliminary TRA (i.e., HLCRA);
(8) Determine preliminary security requirements for SuC;
(9) Perform CSAs led by PJS Leader/PJSC or by PDS Leader/PDSC or additionally assigned to Independent Security Assessor, if applicable or required;
(10) Establish and prepare the Security Case – R1 stage, if required;
(11) Perform ICSA and prepare the ICSA Report – R2 stage, if required; and
(12) Hold Formal Review Meetings before the end of R1 stage.

2 Development/Design and Development (R2) - Detailed Risk Assessment, if applicable

(1) Determine SuC and begin preliminary design;
(2) Update SuC after preliminary design, if necessary;
(3) Confirm Zones and Conduits;
(4) Conduct detailed TRA, (i.e., Detailed Security Risk Assessment or DRAR), if applicable;
(5) Apportionment of the System’s or IACS Automation Solution’s CSRS (or CRS), if applicable or required;
(6) Prepare and review Preliminary Security Case, if required; and
(7) Perform CSAs led by PJS Leader/PJSC (or PDS Leader/PDSC) or additionally assigned to Independent Security Assessor, if required;
(8) Hold Formal Review Meetings before the end of R2 stage.

According to the reference document – the SI/SM Project and System Security Management Guideline and Appendix A of this document, the following tasks must be planned and executed:

(1) Planning the tasks and activities of the Concept/Specification - Project

Initiation (R1) and Development/Design and Development (R2) - Detailed Risk Assessment, if applicable;

(2) Preparing the necessary procedures and test plans;

(3) Performing Security Risk Assessment (i.e., TRA);

(4) Completing the Security Risk Assessment Reports (i.e., TRA Report form HLCRA and/or DRAR, if applicable); and

(5) Determining the CSRS (or CRS).

The proforma forms of HLCRA and DRAR workbooks given in Table 4 and Table 5 of the guideline can be used to conduct the HLCRA and detailed Security Risk Assessment (i.e, the Preliminary TRA and the Detailed TRA or DRAR) respectively. In order to effectively maintain the threat model in a Secure System's or IACS Automation Solution's lifecycle, manage security performance, audit and monitor the effectiveness of safety/security preventive and/or mitigating safety/security control measures/ safety/security countermeasures/ safety/security compensating countermeasures, perform accident investigation of security incidents, and feedback and analysis from any security incident to effectively update the threat model, a visual threat modelling method, i.e. so-called Bowtie Method, can also be used for threat modelling, risk assessment, and security management.

3 Development/Design and Development (R2) - Critical Security Design Review

(1) Hold Security Review Meetings to discuss or review the SuC concept design, architecture design, the design of security measures, countermeasures, or an alternate means security risk reduction, if necessary;

(2) Perform CSAs led by PJS Leader/PJSC or by PDS Leader/PDSC or additionally assigned to Independent Security Assessor, if applicable or required;

(3) Establish and prepare the Security Case – R2 stage, if required;

(4) Perform ICSA and prepare the ICSA Report – R2 stage, if required;

(5) Hold Formal Review Meetings before the end of R2 stage, discuss or review:

- the Asset Inventory List
- the Security Architecture - Network and Data Flow Diagram
- the Cyber Threats and Vulnerability Log (i.e., the Security Risk Register);
- the CSRS (or CRS);
- the Security Critical Elements, Requirements, and List, if appropriate; and
- the Security Case/ICSA Report – R2 stage, if required.

4 Production/Implementation and Verification and Validation (R3)

(1) Establish or Update the System's or IACS Automation Solution's asset hardening best practices, if required;

(2) Verify the Hardening Best Practices had already been implemented correctly and completely;

(3) Establish the Security Policies and Procedures and/or Security Functional Description Specification for the System or IACS Automation Solution, including:
- Account Management;
- Vulnerability Management;
- Backup and Restore Procedures;
- Change and Patch Management Procedures;
- Logging, Monitoring, and Reporting Procedures; and
- System Malware Protection Procedures.

(4) Establish and prepare the Security Solution Integration Plan for Security Policy and Procedure Design Best Practices, if required or necessary;

(5) Establish and prepare the Security Inspection and Test Protocol which including FAT, SAT, and/or SIT test package, if applicable;

(6) Establish and prepare the SVVP, if required or necessary;

(7) Establish and prepare the Incident Response and Recovery Plan/Procedures, if applicable;

(8) Establish and prepare the FAT, SAT, and/or SIT Test Cases which related to security, if required or necessary;

(9) Perform FAT, SAT, and/or SIT test packages (if required or necessary);

(10) Perform Source Codes Review, if applicable;

(11) Establish and prepare the Source Codes Review Report, if applicable

(12) Establish and prepare the SBOM, if required or necessary;

(13) Perform Application and Vulnerability Assessment Testing, if applicable

(14) Establish and prepare the Application and Vulnerability Assessment Testing Report, if applicable;

(15) Establish and prepare the Penetration Testing Cases, if required;

(16) Perform Penetration Testing, if required;

(17) Establish and prepare the FAT, SAT, and/or SIT Test Reports (if required or necessary);

(18) Establish and prepare the Penetration Testing Report, if required;

(19) Establish and prepare the SLA Protocol, if required (For supporting the security management during the stages in R4 and in R5);

(20) Perform CSAs led by PJS Leader/PJSC or by PDS Leader/PDSC or additionally assigned to Independent Security Assessor, if applicable or required;

(21) Establish and prepare the Security Case – R3 stage, if required;

(22) Perform ICSA and prepare the ICSA Report – R3 stage, if required; and

(23) Hold Formal Review Meetings before the end of R3 stage.

5 Project Closing (Before the end of R3 stage), if required

(1) Implement necessary countermeasures or improvement plans for the

security issues discovered in the Stages of R1, R2, and/or R3, so that all discovered security issues can be completely solved and processed during the overall SI/SM Project lifecycle;

(2) Verify the Security Policies and Procedures and/or Security Functional Description Specification for the System or IACS Automation Solution, if required;

(3) Verify the SLA Protocol, if required; and

(4) Hold Formal Review Meetings to close R3 stage.

5.6.5 網宇威脅和漏洞日誌 Cyber Threats and Vulnerability Log

A Cyber Threats and Vulnerability Log should be implemented by the ICP and maintained by the designated PDS Leader/PDSC of P/SSO and used as a threats-tracking tool, at the system level and at the sub-system and/or HW/SW-level, if applicable of the System or IACS Automation Solutions (i.e., the SuC). It will allow recording, monitoring, and tracking of the implementation of security provisions to reduce risk throughout the Project and the SuC, up to the end of the SuC being hand overed to the Asset Owner or the SuC's Users.

The Cyber Threats and Vulnerability Log should be recorded by using the proforma form given in Table 6 of the guideline when applicable. If any change or update was done in each Cyber Threats and Vulnerability Log submission to the PJSC or to the PDSC and/or its subcontractors/vendors/suppliers will highlight the change made.

A history log or change records shall be maintained to record each cyber threat update to facilitate traceability. The change records of the Cyber Threats and Vulnerability Log can be recorded by using the proforma form given in Table 7 of the guideline.

Notice that, in general, the Cyber Threats and Vulnerability Log and its change records will be recorded and updated via a supporting software tool progressively.

5.6.6 安全關鍵要素、要求和清單 Security Critical Elements, Requirements, and List

A Security Critical Elements, Requirements, and List should be built for each sub-system, equipment, component, and device of the SuC with the results of the various Security Studies and/or analyses performed all along with the Secure SI/SM Project progress. The Security Critical Elements, Requirements, and List gathers items which may, in the case of non-compliance with the identified security requirements, potential lead to a Critical or Major cyber threat incident. Security relevant critical elements or items can be a product, an interface, a task (e.g., operation, maintenance, etc.), or a function.

The Security Critical Elements, Requirements, and List should be established by using the proforma form given in Table 8 of the guideline if applicable.

5.6.7 網宇威脅管理系統 Cyber Threats Management System

For the System, the cyber threats management requirements specified in the ICP's SI-SM Project Security Management Planning Guideline shall be applied to. It will

be managed and supported via the ICP's relevant cyber threats management system appropriately.

5.7 安全保證管理 Security Assurance Management

5.7.1 品質管理 Quality Management

For the Project and the System, the requirements specified in the ICP's SI-SM Project Security Management Planning Guideline and/or the ICP's SI, SM Project and System Security Management Guideline as well as the ICP's quality management systems' requirements shall be applied to.

5.7.2 安全管理 Security Management

For the Project and the Product, the requirements specified in the Section 5.7.2 of the ICP's SI-SM Project Security Management Planning Guideline and/or the ICP's SI, SM Project and System Security Management Guideline as well as the ICP's quality management systems' requirements shall be applied to.

5.7.3 安全審查、稽核和評鑑 Security Reviews, Audits, and Assessment

For the Project and the Product, the requirements specified in the Section 5.7.3 of the ICP's SI-SM Project Security Management Planning Guideline and/or the ICP's SI, SM Project and System Security Management Guideline as well as the ICP's quality management systems' requirements shall be applied to.

6.0 References：

[1].ICP - The SI,SM Project and System Security Management Guideline.pdf
[2].ICP - The SI,SM Project and System Security Management Guideline – Annexes.pdf
[3].ICP - 整合_維護服務專案安全管理規劃指南(SI-SM Project Security Management Planning Guide.pdf

<<Text End>>